



State of Ohio Administrative Policy

Information Technology Supplier Risk Management

No: IT-21

Information Technology

Effective:

August 25, 2025

Issued By:

Kathleen C. Madden, Director

I. Purpose

The purpose of this policy is to define statewide Information Technology (IT) Supplier Risk Management requirements for IT-related services, solutions, and products to help protect State Data and operations and mitigate the Risk of Information Security and Privacy Incidents.

All defined terms are capitalized and a link to the glossary of definitions is found in section IV.

In addition, references to National Institute of Standards and Technology (NIST) Special Publication 800-53, "Security and Privacy Controls for Information Systems and Organizations," System and Services Acquisition (SA) and Supply Chain Risk Management (SR) family identifiers and control numbers are provided in parentheses next to requirements, where applicable.

II. Scope

This policy applies to all agencies, boards, and commissions under the authority of the Governor (collectively referred to as Agency or Agencies).

III. Policy

Agencies must mitigate against the Risks associated with utilizing IT Suppliers to help ensure the Confidentiality, Integrity, and Availability of State Data as well as IT services and solutions. Agencies must also evaluate and monitor IT Supplier Risk and compliance to minimize potential disruptions and negative impacts to State of Ohio operations (SA-9, PM-30, SR-1). To assist in these efforts, Agencies must align with the requirements outlined below.

- A. **DAS IT Supplier Risk Management Program:** The DAS Office of Information Security and Privacy (OISP) must design, manage, and maintain a statewide IT Supplier Risk Management program.

1. DAS OISP must establish a framework for evaluating and monitoring IT Supplier products, solutions, or services, including their information security and privacy practices and other Risk factors.
2. DAS OISP must review the IT Supplier Risk Management program on a biennial basis to determine if any changes are needed.

B. **Agency IT Supplier Risk Management:** Agencies must establish procedures to align with the DAS OISP IT Supplier Risk Management Program requirements in this policy as well as State of Ohio IT Standard ITS-SEC-05, "IT Supplier Risk Management." This is regardless of whether procurements are coordinated with the DAS Office of Procurement Services (OPS) or via a release from the OPS request to purchase process.

IV. Definitions

All defined terms are capitalized within the policy and the online glossary of definitions can be found at <https://das.ohio.gov/technology-and-strategy/it-policy-glossary>.

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf
Ohio Administrative Policy IT-13, Data Classification	https://das.ohio.gov/technology-and-strategy/policies/it-13
State of Ohio IT Standard ITS-SEC-05 IT Supplier Risk Management	https://ohid.ohio.gov/wps/myportal/gov/myohio/my-resources/oisp/oisp-services/information-security-privacy-standards/its-sec-05-information-technology-supplier-risk-management
Ohio Office of Budget and Management SAFE Manual	https://finsource.ohio.gov/SAFEManual/index.htm#t=welcome to the safe manual.htm

Document Name	Location
Data Security and Privacy Terms	https://procure.ohio.gov/state-and-local-agencies/resources/04_Resources_Forms
Ohio Administrative Policy PM-01 Purchasing Goods and Services	https://das.ohio.gov/buying-and-selling/policies/purchasing-goods-and-services-pm-01

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

1-614-644-6860 | state.isp@das.ohio.gov

State of Ohio Administrative Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy must be reviewed no less than every two years and updated as needed.

Date	Description of Change
08/25/2025	Original Policy.